

Week 6 - Task 16: Incident Response Process (NIST Phases)

Intern: Mudasir Zia **Company:** TechBiz Academy — Cybersecurity Internship **Date:** September 24, 2026

1. Objective

Understand the NIST SP 800-61 Incident Response lifecycle (6 phases), apply it to a malware-infection scenario, and define L1→L2 escalation criteria.

2. The 6 NIST IR Phases (One Line Each)

1. **Preparation** — Have logging, monitoring, tools, procedures, and trained staff ready *before* an incident happens.
2. **Detection & Analysis** — Identify and validate the alert, scope the affected host/user, and determine if it's malicious.
3. **Containment** — Stop the threat from spreading (short-term: isolate immediately; long-term: keep it controlled while investigating).
4. **Eradication** — Remove the malware and any persistence mechanisms from the environment.
5. **Recovery** — Restore the system to normal, verified-clean operation and monitor for recurrence.
6. **Lessons Learned** — Review the whole incident afterward and fix the gaps that let it happen.

3. Containment: Short-Term vs Long-Term

Type	Goal	Example
Short-Term	Immediately stop spread/communication	Isolate the infected workstation from the network right away, while preserving it for investigation
Long-Term	Hold the system in a controlled state during deeper investigation	Keep it isolated, restrict affected accounts/network access, don't restore to production until root cause is confirmed

L1 Responsibility: Follow the approved containment procedure, document every action, preserve evidence, and escalate if containment needs actions beyond L1 authorization.

4. Scenario Walkthrough — Suspected Malware Infection

Scenario: A user opens an unexpected email attachment on a Windows workstation. The SOC then detects suspicious PowerShell activity on that host.

What Happens

Phase	
Preparation	Endpoint protection, centralized logging, SIEM, and documented IR procedures are already in place before this incident occurs.
Detection & Analysis	SOC gets an alert for suspicious PowerShell activity. L1 identifies the host/user, checks the timeline, reviews Windows logs, and assesses whether it's malicious.
Containment	Affected workstation is isolated from the network (short-term) and kept isolated while investigation continues (long-term).
Eradication	L2/IR personnel remove the malware and any persistence mechanisms; compromised credentials are reset.
Recovery	Workstation restored to a trusted state, security controls verified, monitoring increased to catch recurrence.
Lessons Learned	SOC reviews detection-to-recovery timeline, identifies gaps, and records improvements.

Initial L1 SOC Actions Taken: 1. Reviewed alert details 2. Identified affected workstation and user 3. Determined approximate incident time 4. Reviewed available Windows/security logs 5. Checked the suspicious PowerShell activity 6. Assessed whether activity is malicious 7. Recorded evidence and prepared for escalation if needed

Initial Assessment: Activity is suspicious and requires further investigation. **Potential Impact:** Workstation may be compromised; risk of communication with malicious infrastructure or further malicious activity.

Possible Improvements Identified (Lessons Learned): - Improve detection rules for suspicious PowerShell activity - Review email attachment security controls - Improve endpoint monitoring - Update incident-response procedures - Additional user security-awareness training

5. L1 → L2 Escalation Note

L1 normally handles: initial alert validation, basic investigation, evidence collection, documentation, and authorized first-response actions.

Escalate to L2 when: 1. Multiple systems appear affected 2. Evidence of active attacker access 3. Malware persistence is suspected 4. Advanced malware analysis is required 5. Endpoint forensics is required 6. Significant business/operational impact 7. Privileged or sensitive accounts may be compromised 8. Containment requires actions outside L1 authorization 9. Root cause can't be determined with L1 procedures 10. Incident continues/worsens after initial containment

Escalation Decision for This Scenario: L1 validates the alert, identifies the affected workstation, collects initial evidence, and performs authorized containment. If investigation shows persistence, additional compromised systems, credential compromise, active attacker access, or a need for advanced forensics/malware analysis,

Practical Notes – Incident Response Documentation (Part 2)

```
"Incident-notes.txt - Notepad
File Edit Format View Help

Long-Term Containment:
The objective is to maintain the affected system in a controlled state while deeper investigation and remediation are performed.

Example:
Keep the workstation isolated, restrict affected accounts or network access where necessary, and continue investigation before returning the system to normal operation.

SOP 12 - Remediation:
LI should follow the organization's approved containment procedures, document every action, preserve relevant evidence, and escalate when containment requires actions outside LI authorization.

Escalation:
If the incident involves multiple systems, suspected active attacker access, persistence, significant business impact, advanced malware analysis, or actions outside LI authorization, escalate to L2/incident response personnel.

6-PHASE INCIDENT RESPONSE METHODOLOGY

Detection:
A user opens an unexpected email attachment on a Windows workstation. Shortly afterward, the SOC detects suspicious PowerShell activity. The workstation is suspected of being infected with malware.

PHASE 1 - PREPARATION
The organization maintains endpoint protection, centralized logging, IDS/IPS monitoring, incident-response procedures, user reporting channels, and trained SOC personnel. The SOC has documented procedures for investigating and containing suspected malware incidents.

LI SOC Action:
Identify PowerShell logs, alerts, monitoring, and escalation procedures are available before incidents occur.

PHASE 2 - DETECTION & ANALYSIS
The SOC receives an alert for suspicious PowerShell activity. The LI analyst reviews the alert, identifies the affected host and user, checks the event timeline, examines available Windows logs, and determines whether the activity is potentially malicious.

LI SOC Action:
Reinforce the alert, collect initial evidence, determine scope, classify severity, and document findings.

PHASE 3 - CONTAINMENT
The affected workstation is isolated from the network according to the organization's incident-response procedure. This reduces the possibility of malware communicating externally or spreading to other systems.

Short-Term:
Immediately isolate the affected workstation.

Long-Term:
Notify/IT control isolate while investigation and remediation continue.

LI SOC Action:
Remove malware containment and document the action. Evaluate if advanced containment is required.

PHASE 4 - ERADICATION
Identify/incident-response personnel identify and remove the malware and any associated persistence mechanisms. Malicious files, unauthorized changes, and compromised credentials are addressed according to organizational procedures.

LI SOC Action:
Provide additional evidence and investigation findings to L2/incident-response personnel when evaluation requires elevated privileges, endpoint forensics, or malware analysis.

PHASE 5 - RECOVERY
After eradication, the workstation is returned to a trusted operational state. Security controls are verified, required credentials are secured, and monitoring is increased to detect possible recurrence.

LI SOC Action:
Notify the relevant support for new suspicious alerts and confirm that normal security monitoring has resumed.

PHASE 6 - LESSONS LEARNED
The incident is reviewed after resolution. The SOC reviews the initial detection, investigation, containment, evaluation, and recovery actions. Gaps are identified and recommendations are recorded.

Relevant Information:
- Review malware analysis for suspicious PowerShell activity.
- Review endpoint monitoring.
- Update incident-response procedures.
- Provide additional user security awareness training.

LI TO L2 ESCALATION NOTE
LI SOC analysts currently perform initial alert validation, basic investigation, evidence collection, documentation, and authorized first-response actions.

The incident should be escalated to L2 when:
1. Multiple systems appear affected.
2. There is evidence of active attacker access.
3. Account persistence is suspected.
4. Account related activity is repeated.
5. Endpoint forensics is required.
6. The incident has significant business or operational impact.
7. Persistence or malicious activity may be suspected.
8. Containment requires actions outside LI authorization.
9. The user cannot comply with authorized logging controls.
10. The incident continues or recurs after initial containment.

Escalation Action:
The LI analyst validates the suspicious PowerShell alert, identifies the affected workstation, collects initial evidence, and performs authorized containment.

If investigation indicates persistence, additional compromised systems, credential compromise, active attacker access, or a need for advanced forensic/malware analysis, LI escalates the incident to L2/incident-response personnel.

Escalation should include:
- Alert details
- Affected host/user
- Timeline
- Relevant log evidence
- Action history performed
```

IR Notes Part 2

Practical Notes — Incident Response Documentation (Part 3)

```
"Incident-notes.txt - Notepad
File Edit Format View Help

Immediately isolate the affected workstation.

Long-Term:
Notify/IT control isolate while investigation and remediation continue.

LI SOC Action:
Remove malware containment and document the action. Evaluate if advanced containment is required.

PHASE 4 - ERADICATION
Identify/incident-response personnel identify and remove the malware and any associated persistence mechanisms. Malicious files, unauthorized changes, and compromised credentials are addressed according to organizational procedures.

LI SOC Action:
Provide additional evidence and investigation findings to L2/incident-response personnel when evaluation requires elevated privileges, endpoint forensics, or malware analysis.

PHASE 5 - RECOVERY
After eradication, the workstation is returned to a trusted operational state. Security controls are verified, required credentials are secured, and monitoring is increased to detect possible recurrence.

LI SOC Action:
Notify the relevant support for new suspicious alerts and confirm that normal security monitoring has resumed.

PHASE 6 - LESSONS LEARNED
The incident is reviewed after resolution. The SOC reviews the initial detection, investigation, containment, evaluation, and recovery actions. Gaps are identified and recommendations are recorded.

Relevant Information:
- Review malware analysis for suspicious PowerShell activity.
- Review endpoint monitoring.
- Update incident-response procedures.
- Provide additional user security awareness training.

LI TO L2 ESCALATION NOTE
LI SOC analysts currently perform initial alert validation, basic investigation, evidence collection, documentation, and authorized first-response actions.

The incident should be escalated to L2 when:
1. Multiple systems appear affected.
2. There is evidence of active attacker access.
3. Account persistence is suspected.
4. Account related activity is repeated.
5. Endpoint forensics is required.
6. The incident has significant business or operational impact.
7. Persistence or malicious activity may be suspected.
8. Containment requires actions outside LI authorization.
9. The user cannot comply with authorized logging controls.
10. The incident continues or recurs after initial containment.

Escalation Action:
The LI analyst validates the suspicious PowerShell alert, identifies the affected workstation, collects initial evidence, and performs authorized containment.

If investigation indicates persistence, additional compromised systems, credential compromise, active attacker access, or a need for advanced forensic/malware analysis, LI escalates the incident to L2/incident-response personnel.

Escalation should include:
- Alert details
- Affected host/user
- Timeline
- Relevant log evidence
- Action history performed
```

IR Notes Part 3

End of report.